

DOCKER

Modül 17.8.4

Image Tarama (Vulnerability Scanning)

Image'lardaki güvenlik açıklarını bulmak

Data Science RoadMap

Alican Kaya

github.com/AlicanKaya192

Neden Tarama Yapmalıyız?

Sizin kodunuz ne kadar güvenli olursa olsun, Dockerfile içinde `FROM node:14` veya `FROM python:3.7` yazdığınızda arka planda yüzlerce Linux paketi indirilir. Bu paketlerin içinde bilinen kritik güvenlik açıkları (CVE - Common Vulnerabilities and Exposures) bulunabilir.

Docker Scout

Docker'ın kendi içine entegre ettiği yeni zafiyet tarama aracıdır. Image'lerinizi analiz ederek kritik açıkları ve onları kapatmak için hangi 'base image'a geçmeniz gerektiğini size söyler.

```
bash

# İmajınızın içindeki açıkları listele
docker scout cves my_app:latest

# Sana daha güvenli bir Base Image tavsiyesi vermesini iste
docker scout recommendations my_app:latest
```

Trivy (Açık Kaynak Alternatif)

Endüstride en çok kullanılan, inanılmaz hızlı ve ücretsiz açık kaynak tarayıcıdır. Genellikle CI/CD (GitHub Actions, GitLab CI) boru hatlarına entegre edilerek, güvenlik açığı olan imajların canlıya alınması engellenir.

```
bash

# Trivy'i Docker içinden çalıştırarak yerel imajı tarama
docker run --rm -v /var/run/docker.sock:/var/run/docker.sock \
  aquasec/trivy image my_app:latest
```

[+] Güvenli İmaj Stratejisi

- Daima resmi (Official) image'lar kullanın
- Latest yerine spesifik sürüm tagleri kullanın (örn: 1.14.2)
- Mümkünse 'alpine' veya 'slim' gibi küçük/hafif imajlar seçin

[-] Riskli Davranışlar

- Rastgele kullanıcıların (john123/mysql) imajlarını kullanmak
- Zafiyet taraması yapmadan kod canlıya (production) almak
- Eski (EOL - desteği bitmiş) işletim sistemi imajlarına tutunmak